

Invariant[✓]

lagon Reputation

Solo Audit Report v1

June 30, 2025

Contents

Revision table	1
1 Executive summary	2
Project overview	2
Audit overview	3
	3
	5
	7
	8
	9
	10
	11
	12
	13
	14
	14
	16
	17
	18
	20
	21

Revision table

Report version	Report name	Date	Report URL
1.0	Main audit	2025-06-30	

1 Executive summary

THIS REPORT DOES NOT PROVIDE ANY WARRANTY OF QUALITY OR SECURITY OF THE AUDITED CODE and should be understood as a best efforts opinion of Invariant0 produced upon reviewing the materials provided to Invariant0. Invariant0 can only comment on the issues it discovers and Invariant0 does not guarantee discovering all the relevant issues. Invariant0 also disclaims all warranties or guarantees in relation to the report to the maximum extent permitted by the applicable law. This report is also subject to the full disclaimer in the appendix of this document, which you should read before reading the report.

Project overview

lagon reputation smart contracts are a small Cardano on-chain part of the lagon protocol which is a decentralized storage protocol working mostly outside of the blockchain. The reputation of users is stored outside of the Cardano blockchain as well, in a centralized L2. The audited on-chain consists of the following contracts:

- *Reputation script*. Users can create their reputation UTxO which stores a hash of their reputation data that is otherwise stored only outside. There is a reputation token minted to uniquely identify the UTxO across updates. An *operator*, an lagon-controlled backend hot key, is necessary at all steps to validate the reputation hash that is put in the UTxO by signing off the transaction; that includes the reputation UTxO creation and all updates. A user can at any time remove the UTxO from the script without any interaction from the operator. Updates to the reputation hash can be requested both by the user and done solely by the operator without any interaction from the user.
- *Fee script*. Fee UTxOs contain Ada used for transaction fees in transactions involving batch updates to users' reputation. Since reputation updates are done by the operator, its usage requires operator's signature. If used, only the actual transaction fee can be unlocked at a time. Aside from unlocking Ada to cover transaction fees, the script supports adding more Ada to the UTxO as well.

It is important to note that there is no on-chain validation of the actual validity of the reputation data hash — it relies solely on the operator's trustworthiness. The operator key can not be updated and a new redeployment as well as downstream coordination of its consumers are necessary if the key is ever compromised.

Audit overview

I started the audit at commit `0d4f314c3b` and it lasted from June 24, 2025 to June 30, 2025. The timeframe is inclusive of periods in which I was awaiting the implementation of fixes by the client. We interacted mostly on Discord. The team fixed all issues to my satisfaction, except for 1 minor finding that was acknowledged, and 3 informational findings that were acknowledged as intended. They do not represent security threats to the system and can be mitigated by proper expectation management and communication. I found the team responsive and collaborative throughout the audit process.

The scope of the audit was limited to the smart contract files only. I did not review any tests or any other components of the system as part of this audit. I performed a design review along with a deep manual audit of the code and reported findings along with remediation suggestions to the team in a continuous fashion, allowing the time for a proper remediation that I reviewed afterwards. See more about our methodology in Methodology.

The commit `c48b02afb9fa6f2440b84cb430303632b5c7f18f` represents the final version of the code. The status of any issue in this report reflects its status at that commit. You can see all the files audited and their hashes in Audited files. The smart contract language used is Aiken and the contracts are intended to run on Cardano. To avoid any doubt, I did not audit Aiken itself.